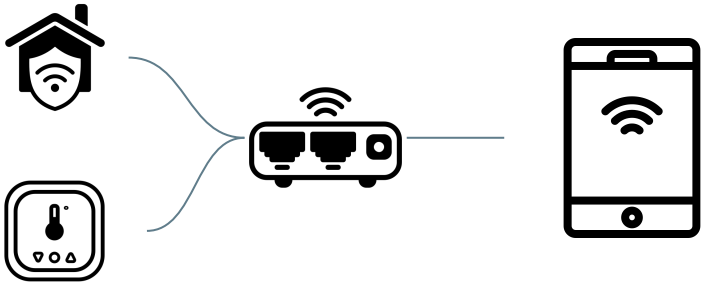
Dynamic Analysis - Fuzzing

We acknowledge funding provided by Microelectronic Commons and the support of OUSW(R&E).

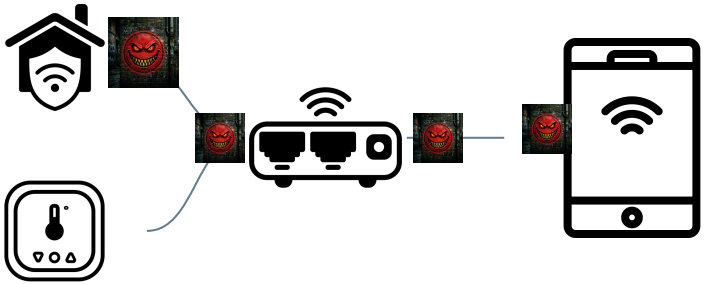
Where to fuzz?

Controller accesses device through Hub.



Where to fuzz?

Controller accesses device through Hub.



Where to fuzz?

- IoT Device mimicking edge/cloud/controller.
- Edge/Cloud mimicking device.
- Edge/Cloud mimicking controller.
- Controller mimicking edge/cloud/device.

Fuzzing IoT Device

Smart thermostat:

- Authentication and Authorization.

- Set/View temperature.



Fuzzing IoT Device

- Generate inputs.
- Execute program with these inputs.
- Observe (identify) invalid behavior.

Fuzzing IoT Device: Input Generation

Fuzzing IoT Device: Input Generation

Well-know input formats v/s custom input formats.

Stateful v/s stateless inputs.

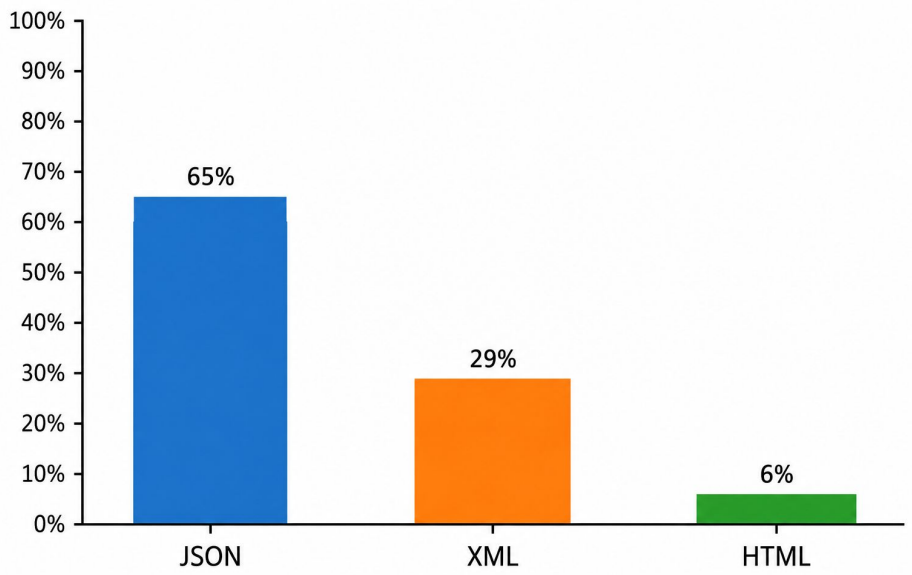
Fuzzing IoT Device: Input Generation

Well-know input formats v/s custom input formats:

- Text/structured: JSON, XML, CSV
- Compact structured: CBOR, MessagePack
- Schema-based binary: Protocol Buffers, ASN.1, XDR
- Simple binary: TLV and packed C structures
- Vendor-specific/proprietary binary: very common at BLE, UART, Zigbee, industrial, and firmware interfaces

Fuzzing IoT Device: Input Generation

Input formats in internet connected devices:



https://www.researchgate.net/publication/360323731_A_Survey_on_the_Web_of_Things?utm_source=chatgpt.com

Generating JSON Messages

- JSON REST/API fuzzing → Schemathesis
- Stateful REST sequences → RESTler
- Native JSON parser fuzzing → AFL++ / libFuzzer + JSON-aware grammar
- Simple mutation of captured JSON → Radamsa
- Generate schema-valid JSON seeds → JSON Schema Faker

Fuzzing IoT Device: Input Generation

- Identify input schema.
- Find a generator for that schema:
  - Consider stateful v/s stateless.

Fuzzing IoT Device: Execution

Fuzzing IoT Device: Execution

- On device:
  - Buy the device, configure and send inputs.

- Emulator:
  - Identify an emulator, extract the firmware, execute (and send inputs).

Fuzzing IoT Device: Execution

- On device:
  - Buy the device, configure and send inputs.
  - Does not scale.

- Emulator:
  - Identify an emulator, extract the firmware, execute (and send inputs).
  - Issues with fidelity and availability.

Fuzzing IoT Device: Identify Invalid Behavior

Fuzzing IoT Device: Identify Invalid Behavior

- Invalid output.
- Device non-responsive.
- Known bad error code.

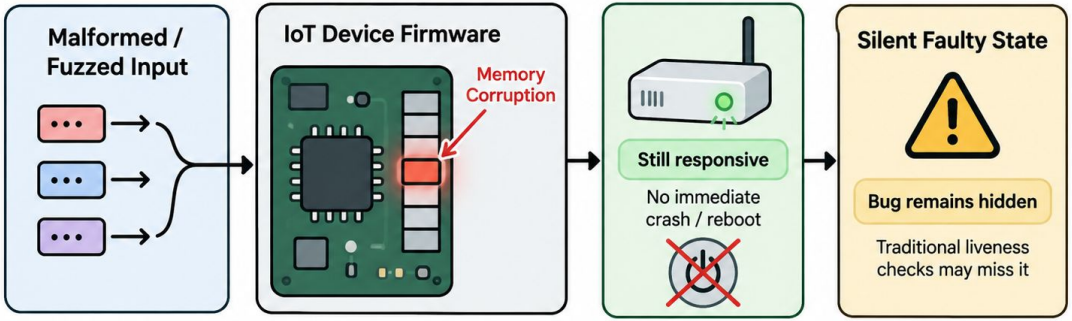
Fuzzing IoT Device: Identify Invalid Behavior

- Invalid output.

- Device non-responsive:
  - How long should we wait? 2 min? 5 min?

- Known bad error code:
  - 500 (for HTTP)

Fuzzing IoT Device: Identify Invalid Behavior



In embedded/IoT devices, memory corruption may not lead to an observable crash.

Why?

Memory corruption might not lead to crashes!

(Typically) Memory corruption => Tries to access invalid memory => Unmapped or invalid permissions in virtual address space => MMU fault => Crash

Memory corruption might not lead to crashes!

(Typically) Memory corruption => Tries to access invalid memory => Unmapped or invalid permissions in virtual address space => MMU fault => Crash.

In embedded devices:

Memory corruption => Tries to access invalid memory => ~~Unmapped or invalid permissions in virtual address space~~ => ~~MMU fault~~ => ~~Crash~~.